

采埃孚商用车系统 (青岛) 有限公司

X.509 PKI SOW

2023/11

目录

1. 项目简介	4
1.1 项目背景	4
1.2 项目目标	4
1.3 项目需求	5
1.3.1 PKI 建设需求	5
1.3.2 项目供货内容	5
1.4 项目范围	6
1.5 项目技术要求	7
1.6 项目主实施计划	7
1.7 乙方能力要求	8
2. 技术要求	9
2.1 部署要求	9
2.2 系统部署架构	9
2.3 X.509 PKI 系统	10
2.3.1 CA 技术要求	10
2.3.2 KMS 要求	12
2.3.3 性能要求	12
2.3.4 密码机	13
2.3.5 其他要求	15
3. 运营要求	16
3.1 服务范围	16
3.1.1 功能范围	16
3.1.2 技术范围	16
3.1.3 地理范围	17
3.2 操作要求	18
3.2.1 基础设施	18
3.2.2 应用程序体系结构	19
3.2.3 软件更新	19
3.2.4 性能	21
3.2.5 安全管理	21
3.2.6 维护与运营支持	23
3.3 售后服务要求	25
3.3.1 质保期	25
3.3.2 产品承诺	25
3.3.3 技术支持和服务	25
3.3.4 故障修复时间	25
3.3.5 服务响应时限	25

3.3.6	热线电话	26
3.4	质量保证	26
4.	验收要求	27
4.1	验收标准	27
4.2	验收步骤	27
4.3	交付物要求	28
5.	项目培训	29
5.1	培训目的	29
5.2	技术培训	29
6.	违约和处罚	30
7.	附录文件	31

1.项目简介

1.1 项目背景

智能网联汽车的安全性是一个日益受到行业关注的问题，随着现代车载电子设备的复杂性以及无线接口、可下载应用程序和连接的消费设备的集成，扩大了攻击面。

这需要基于公钥基础设施（PKI）的安全架构来解决车载设备和车到云通信的安全性、互操作性和隐私问题。PKI 作为建立在密码技术基础上的信息安全技术和安全体系架构，是一种经过验证的解决方案，在其应用的几十年来一直受到信任。现在，数十亿连接到互联网的设备和系统使用 PKI，并由 PKI 提供加密、验证用户或设备以及验证身份。这是一种适应性强的技术，可以以多种方式用于车辆，但 PKI 也可用于允许单个车辆（甚至车辆中的单个芯片）进行身份验证、加密系统之间发送的数据并提供完整性检查。

通过建设 PKI 系统，为采埃孚零部件设备提供强身份认证保护功能，采用 PKI 云端系统，方便快捷的为采埃孚零部件设备和用户诊断仪签发设备证书和用户诊断证书，完成诊断仪和零部件设备的合法验证。

1.2 项目目标

项目目标 1：满足采埃孚商用车 X.509 格式证书签发需求，为采埃孚工厂、售后、诊断等场景提供 X.509 格式证书

项目目标 2：满足采埃孚商用车密钥需求，根据采埃孚要求开发 KMS 管理页面，并提供完整的 KMS 管理系统

1.3 项目需求

1.3.1 PKI 建设需求

公钥基础设施(Public Key Infrastructure, 简称 PKI)是采用非对称密码算法和技术, 来实现并提供安全服务, 并具有通用性的安全基础设施, 是一种遵循标准的密钥管理平台。它能够对所有网络应用透明地提供采用加密和数字签名等密码服务所必需的密钥和证书管理。

通过建设采埃孚根 CA 体系下的二级 PKI 体系, 为本项目业务中的对象签发统一的数字身份标识—数字证书, 从而构建一个安全的网络环境, 为实现信息的保密性、完整性, 并完成身份鉴别以确保不可抵赖性提供基础支撑。

1.3.2 项目供货内容

乙方提供的产品与下列产品的技术规格、技术参数、性能、功能、质量指标要完全相符, 具体配置如下:

- X.509 供货内容

序号	产品名称	说明	设备规格	单位	数量
1	X.509 根证书签发管理系统	根 CA, 提供二级 CA 证书签发功能		套	1
2	二级证书签发管理系统 (CA)	面向采埃孚各实体对象负责数字证书的申请、签发、更新、挂起、冻结、注销等安全功能	证书最小签发并发 50 张/秒	套	1
3	二级证书注册管理系统 (RA)	面向采埃孚各实体对象与签发系统配合实现证书的申请、审核、更新等一系列生命周期管理	证书最小申请并发 50 张/秒	套	1
4	目录服务系统 (LDAP)	轻量级目录访问协议 (LDAP) 服务, 提供用户数字证书的快速搜索和查询服务, 对外提供证书撤销列表 (CRL) 的搜索、查询和下载等服务	支持精确查询 (100 万条目), 单线程响应速度 < 5ms, 50 线程响应速度 < 15ms; 支持模糊查询 (100 万条	套	1

			目)，单线程响应速度 < 100ms，50 线程响应速度 < 800ms；		
5	证书状态快速查询系统 (OCSP)	证书状态在线查询协议服务，可以为用户提供实时的证书状态查询，包括撤销、冻结、有效、过期、未生效等	证书查询效率最小并发 500 张/秒	套	1
6	密钥管理系统 (KMS)	根据甲方要求提供 KMS 界面 GUI，提供密码算法调用接口，可指定密钥标识通过 KMS 完成数据密码运算，包括对称\非对称加解密、签名、验签等操作	支持 RSA/ECC/ED25519 非对称密钥，支持 AES 对称密钥运算	套	1
7	数字签名服务器	根据甲方要求提供数字签名服务器，支持针对固件等签名需求	支持 ED25519 算法，支持 GUI 界面	套	1
8	密码机	提供 X.509 PKI 体系的密钥管理和密码运算服务。	ED25519 密钥对生成不小于 8 对/秒，签名运算性能不低于 300 次/秒，验签速度不小于 8000 次/秒；	台	2

1.4 项目范围

通过构建基础密码设施平台，提供完整的云-管-端一体的智能网联汽车信息安全解决方案，本项目需要基于 PKI 技术、相关密码学技术、《证书认证系统密码及相关技术规范》以及国内外相关标准规范要求进行 PKI 体系建设，构建功能完善、技术先进、安全可靠、服务领先的数据安全防护系统建立起安全、有效的信息安全系统运行管理机制。本次项目至少应包括如下组件和功能：

- 1) X.509 PKI 系统
- 二级 CA 系统：面向本单位实体对象提供数字证书的申请、签发、更新、挂起、冻结、注销等安全功能；

- 注册管理系统 (RA)：面向本单位实体对象与签发系统配合提供证书的申请、审核、更新等一系列生命周期管理等功能；
 - 目录服务系统 (LDAP)：提供符合 RFC 标准的数字证书/CRL 的存储、发布、查询等功能；
 - 证书状态快速查询体系 (OCSP)：提供证书状态快速查询服务
- 2) 密码机：
- 为 X.509 PKI 系统提供密钥生成、分发、存储、销毁等功能，密钥管理和密码运算服务。

1.5 项目技术要求

- 1) 系统需至少支持双机负载均衡提供服务，即某一节点故障时需保障服务正常运行；
- 2) 系统应支持其他系统调用进行证书签名，服务接口形式为 Restful API 接口；
- 3) 系统应支持 ED25519,RSA-PSS,ECDSA,RSA 等相关签名算法
- 4) 系统应支持使用 AES GCM, ECB, CBC, CTR, CFB 模式加解密
- 5) 系统应满足采埃孚自定义证书扩展项，详见附录 RQ3_Certificate_Specs.pdf
- 6) 系统应支持使用 CMAC-AES-128 和 HMAC-SHA-256 算法

1.6 项目主实施计划

项目实施的主要时间节点如下，除上线节点外，乙方可根据产品实施特点进行调整；

序号	项目阶段	主要工作内容	项目时间
1	项目启动	功能需求分析，技术方案评审	2023.12.25-2024.01.15

2	需求分析	系统方案确认, 功能规范确认, 测试规范确认	2024.01.16-2024.01.31
3	X.509 PKI 建设	X509 PKI 云端建设	2024.02.01-2024.03.31
4	联调测试	PKI X.509 联调测试	2024.04.01-2024.04.15
5	运营	PKI X.509 运营, 协助 ZF 完成 平台、工厂等系统, 并进行试 运营	2024.4.15-2024.12.31
6	项目验收	根据交付物与验收标准, 项目 验收	2025.01.01-2025.01.31

1.7 乙方能力要求

- 1) 乙方须具备有效的营业执照复印件, 并不得违反国家限制经营、特许以及法律行政法规禁止经营的规定, 供应商公司成立时间不少于 5 年, 且注册资金不少于 5000 万, 需提供证明文件;
- 2) 乙方为依法允许经营的事业单位的, 应提交有效的事业单位法人证书和组织机构代码证的复印件;
- 3) 乙方对本项目提供的 X.509 PKI 产品 (含组件) 所有产品必须由原厂商提供, 并提供所有产品的软件著作权证明, 原件备查;
- 4) 乙方应具有整车厂 PKI/CA 项目 (X.509 CA) 建设开发经验, 2018 年 1 月至报价截止时间前独立完成过至少 5 个整车厂 PKI/CA 体系项目建设经验, 提供合同

相关页复印件（包含但不限于商务合同的复印件，须能体现本项业绩要求的内容），盖供应商单位公章，原件备查；

- 5) 乙方及其所提供 X.509 PKI 所有产品需满足国家密码管理局的合规性要求，具备国家密码管理局颁发的商用密码产品认证证书证明，加盖乙方公章，原件备查；
- 6) 乙方需具备 ISO9001、ISO27001 认证证明材料，加盖乙方公章，原件备查。
- 7) 驻本项目项目经理需具有 PMP 或高级项目经理职称。

2.技术要求

2.1 部署要求

系统整体设计需适用于采埃孚业务要求，在满足业务可用的情况下提供高可用的生产环境，PKI 根据业务场景进行方案设计，具备针对不同系统、不同终端、不同型号产品的集成适配能力，其他要求如下：

- 1) 乙方需配合采埃孚零部件及诊断仪在安全业务中的证书的成功应用；
- 2) 系统支持云化方式部署；
- 3) 产品应支持双机热备和负载均衡的部署模式；

2.2 系统部署架构

(1) X.509 CA 系统部署架构

乙方应基于“X.509 PKI 系统部署架构”设计适用于采埃孚汽车的系统部署架构，主要要求包括：

- 1) X.509 PKI 系统满足高可用架构，支持平滑扩容，扩容过程中业务不中断；

- 2) 可适用于采埃孚汽车云平台部署架构;
- 3) 可提供测试系统, 并配合进行系统联调测试, 并对系统试运行阶段出现的问题进行整改。

2.3 X.509 PKI 系统

2.3.1 CA 技术要求

通过建设 PKI 体系, 可为采埃孚零部件及用户等对象签发统一的数字身份标识 X.509 格式数字证书, 从而构建一个安全的网络环境, 为实现信息的保密性、完整性, 并完成身份鉴别以确保不可抵赖性提供基础支撑, 并且能适配及部署到信创环境, 按业务需求可免费支持 PKI 平台扩容。

X.509 数字证书体系功能应包含:

- 证书处理: 支持签发不同终端类型的 X.509 数字证书, 证书支持常见格式(如 pem、der 等)以及证书的内容可做到灵活配置。
- 证书生命周期管理: 提供对管理员证书及用户证书的生命周期管理, 包括证书的申请、签发、更新、挂起、解挂、吊销、发布等。
- 系统管理功能: 系统管理功能包含管理员的管理, 其中 RA 管理员管理包括初始化 RA 管理员申请、增加 RA 管理员、删除 RA 管理员; CA 管理员管理, 包括初始化 CA 管理员申请、后续 CA 管理员证书申请、吊销 CA 管理员证书, 支持管理员的分级管理。
- 账户管理:
 - 个人账户管理, 包括注册信息, 证书信息等管理。
 - RA 账户管理, 包括 RA 账户申请、批准、吊销、额外管理员证书申请等。

- 策略管理：
 - 证书策略管理，高度灵活和可扩展的配置 CA 所签发证书的有效期、证书主题、证书扩展、密钥长度、证书类型等方面，支持自定义证书模版。
 - 审批策略管理，提供自动审批、管理员集中制证等多种方式。
- 统计、审计与日志：
 - 记录所有 CA 与 RA 的操作日志。
 - 对所有操作人员的操作行为进行审计。
- 模板配置：
 - 支持自定义用户终端证书模板，高度灵活和可扩展的配置用户终端证书模板，支持选择不同签发 CA，证书模板。灵活配置自定义扩展项，支持证书模板使用自定义扩展项

LDAP 目录服务系统功能应包含：

系统全面支持轻型目录服务访问协议。

- 提供证书发布存储、查询以及 CRL 发布，支持同步功能；
- 支持向应用提供公钥数字证书的在线查询服务；
- 提供目录服务实例的管理维护功能，包括目录服务的添加、启动、停止、删除等。
- 对目录服务的可信 CA 证书、服务器证书、客户端证书提供统一的管理，包括对证书的添加、查看、删除等功能。
- 提供目录的备份与恢复、数据的导入与导出功能。

- 提供系统配置导入导出、系统备份恢复功能；
- 系统提供良好、易用的管理界面，易于维护与管理；
- 日志审计与归档。
- 支持采埃孚管理 LDAP 数据

OCSP 证书状态查询系统功能应包含：

- 系统完全符合 RFC2560 标准进行证书状态查询。
- 可以支持查询多个不同 CA 颁发的证书，证书应用向 OCSP Server 查询证书状态时。
- 可以一次查询不同 CA 颁发的证书状态，
- 同时支持查询双证书加密证书状态

2.3.2 KMS 要求

- 安全密钥生成，KMS 密钥须采用由国家密码管理局批准使用的物理噪声源产生器芯片生成的随机数；
- 支持支持对称算法及非对称算法密钥批量和单个生成与管理；
- 密钥生成后由加密卡中的内部密钥加密后存储；
- 提供离线下载接口。
- 提供在线分发接口。
- 提供密码算法调用接口，可指定密钥标识通过 KMS 完成数据密码运算，包括对称\非对称加解密、签名、验签等操作
- 提供安全分发方案，保证对称密钥安全地分发到其它系统或供应商。

2.3.3 性能要求

X.509 数字证书体系性能：

- 支持云化部署，并能支持高可用和负载模式；

- 证书的申请速度最小为 50 张/秒
- 证书的下载速度最小为 50 张/秒。

LDAP 目录服务系统性能：

- 满足不小于 300 万台证书并发查询，平均响应时间 1 秒以内。
- 支持条目数不受限制；
- 支持精确查询（100 万条目），单线程响应速度 < 5ms，50 线程响应速度 < 15ms；
- 支持模糊查询（100 万条目），单线程响应速度 < 100ms，50 线程响应速度 < 800ms；
- 100 万条目吞吐量 > 4000 次/秒（50 线程精确查询）；

OCSP 证书状态查询系统性能：

- 满足不小于 300 万证书并发查询，平均响应时间 1 秒以内。
- 证书查询效率 ≥ 500 张/秒。

2.3.4 密码机

提供不少于 2 台密码机用于主备及双机负载

2.3.4.1 功能要求

密码机主要负责 X.509 PKI 密管系统密钥的生成、数字证书签发过程中的密码底层运算等，密码机支持国密和国际等算法，应具备以下功能：

- 密钥生成与管理功能：支持密钥的生命周期管理，采用由国家密码管理局批准使用的物理噪声源产生器芯片生成的随机数。
- 数据加密和解密功能：支持对数据的加密和解密运算。

- 算法支持：支持 SM2 等国密标准非对称算法；RSA, ECC, ED25519 等国际标准非对称算法；支持 SM1、SM4、ZUC 等国密标准对称算法；3DES、AES 等国际标准对称算法；支持 SM3 等杂凑算法。
- 用户访问权限控制功能：具有用户管理功能，提高密码设备自身的安全性。
- 密钥备份及恢复功能：支持基于主密钥保护下的密钥的备份和恢复功能，保证安全应用系统的安全性和可靠性。
- 密钥分层：具备多层密钥保护结构，保障用户密钥安全。
- 安全密钥存储：保证关键密钥在任何时候不以明文形式出现在设备外，密钥备份文件也受到主密钥的保护。
- 支持多机并行：多机并行可以提供容错功能，当有密码机出现故障时不影响业务运算。多机并行还可以提高密码运算性能。
- 密钥使用授权：可配置每对用户密钥对对应一个授权保护码，以保证不同密码应用系统调用同一台密码设备时的密钥安全性。

2.3.4.2 性能要求

- 256 位 SM2 密钥对生成速度不小于 2000 对/秒；
- 256 位 SM2 签名速度不小于 2000 次/秒；
- 256 位 SM2 验签速度不小于 1000 次/秒；
- 256 位 ECDSA 密钥对生成速度不小于 2000 对/秒；
- 256 位 ECDSA 签名速度不小于 2000 次/秒；
- 256 位 ECDSA 验签速度不小于 1000 次/秒；
- 256 位 ED25519 密钥对生成速度不小于 2000 对/秒；

- 256 位 ED25519 签名速度不小于 2000 次/秒;
- 256 位 ED25519 验签速度不小于 1000 次/秒;
- 256 位 SM2 加密速度不小于 1000 次/秒;
- 256 位 SM2 解密速度不小于 2000 次/秒;
- 2048 位 RSA 密钥对生成不小于 8 对/秒;
- 2048 位 RSA 签名速度不小于 300 次/秒 ;
- 2048 位 RSA 验签速度不小于 8000 次/秒;
- SM1 算法加解密速度不小于 150Mbps;
- SM4 算法加解密速度不小于 600Mbps;
- ZUC 算法速度不小于 500Mbps;
- AES 算法加解密速度不小于 700Mbps;
- 3DES 算法加解密速度不小于 250Mbps;
- SM3 杂凑算法速度不小于 600Mbps;
- 最大并发数不小于 1000。

2.3.5 其他要求

- 符合国际和行业标准：系统在设计中遵循相应的国际和工业标准，包括 X.509 标准、PKCS 系列标准，以及 HTTP、SSL、LDAP 等互联网通讯协议等。严格遵循这些标准，使得系统具有很好的开放性，能够与各种应用结合，成为真正的安全基础设施。
- 证书类型多样性及灵活配置：系统能够提供各种证书的签发功能，根据需要，可以进行扩展，通过灵活配置可以签发企业证书、服务器证书、个人用户证书、车机设备证书、移动设备证书、代码签名证书和 VPN 证书等。

- 高安全性和可靠性：使用高强度密码保护密钥，支持加密机等硬件设备，用户关
键信息散列保存，以防遗失。
- 易于部署与使用：系统所有用户、管理员界面都是 B/S 模式，CA/RA 策略配置
和定制以及用户证书管理等都是通过浏览器进行，并具有详细的操作说明。接口
基于 RESTful 风格，易用性良好。
- 高可扩展性：支持弹性伸缩，可在不影响业务情况下，动态扩容。
- 高可用性：高于 99.9%

3.运营要求

3.1 服务范围

3.1.1 功能范围

供应商应负责采埃孚要求的项目阶段 SLA 内的所有运营工作。

3.1.2 技术范围

PKI 应遵循采埃孚批准的持续改进和运营技术标准。

采埃孚技术标准或规范包括但不限于以下列表。

名称	评论

PKI 应遵守中国法规，包括但不限于以下各项。一旦草案版本获得批准和发布，应遵循正式发布的版本。

标准编号。	名称
YD/T 3957-2021	基于 LTE 的车辆通信安全证书管理系统技术要求
YD/T xxxx-xxxx	基于 LTE 的车辆通信安全证书管理系统的测试方法
GB/T 37373-2019	智能运输-数据安全服务
GB/T 37374-2019	智能运输. 证书应用界面
GB/T 37376-2019	运输. 数字证书格式
GB/T 37378-2019	运输. 信息安全规范
YD/T 3594-2019	基于 LTE 的车辆通信的网络安全要求
YD/T 3400-2018	基于 LTE 的车辆通信的一般技术要求
YD/T 3707-2020	基于 LTE 的车辆通信网络层技术要求
YD/T 3708-2020	基于 LTE 的车辆通信网络层测试方法
YD/T 3709-2020	基于 LTE 的车辆通信消息层技术要求
YD/T 3710-2020	基于 LTE 的车辆通信消息层测试方法
YD/T 3340-2018	基于 LTE 的车辆通信空中接口技术要求
YD/T 3756-2020	基于 LTE 的车辆通信的直接通信系统技术要求

3.1.3 地理范围

PKI 应支持在中国的采埃孚零部件相关证书的签发。

3.2 操作要求

3.2.1 基础设施

采埃孚要求：

- 所有基础设施运营应满足业务需求，并考虑未来的扩张。
- 所有服务器应符合采埃孚标准规范。
- 所有基础设施和设施应符合现行行业标准和监管要求。
- 所有信息系统应通过使用多个馈线、不间断电源（UPS）或备用发电机来防止电源故障。
- 设施应具有环境控制，例如火灾/烟雾/水/湿度检测、抑制等。
- 设施内安装的空调和湿度控制器应每天运行二十四（24）小时。
- 应监测计算机环境，包括温度、湿度和电源质量，以确定可能对计算机设备运行产生不利影响的条件。
- 设施应保持在建议的温度和湿度，并发出温度或湿度过高警报。
- 交付和装载区域应与信息处理区域隔离或进行监控，以防止任何未经授权的访问。
- 监控敏感区域的摄像机记录应进行审计，并至少保存 14 天。
- 应根据个人角色和责任所需的频率和时间长度，对设施的物理访问进行授权。访问日志应以电子或印刷形式保存。
- 应建立资产管理流程以监控资产生命周期。

供应商应：

- 确保基础架构主机在 SLA 内遵守上述操作要求。
- PKI 提供外网支持带宽需支持不小于 20M。

3.2.2 应用程序体系结构

采埃孚要求：

- PKI 中的所有数据均属于采埃孚,数据管理应遵循采埃孚和中国政府的数据政策,以保护客户隐私。
- 所有操作系统和软件应获得适当许可, 并在使用限制范围内进行部署。

供应商应：

- 提供支持日常运营的运营组件设计, 例如运营门户、分析、监控等。
- 描述支持操作的角色和责任, 例如管理员、用户等, 以及如何管理这些角色。
- 描述数据管理流程。
- 证明并保持遵守中国法规和标准。

3.2.3 软件更新

采埃孚要求：

- 公司标准-应首先考虑在可能的情况下使用采埃孚公司标准。
- 合法性-确保代码组合利用经批准的组件。
- 兼容性-该软件能够与为互操作性而设计的其他产品一起运行。
- 可扩展性-可以向软件中添加新功能, 而无需对底层架构进行重大更改。
- 模块化-生成的软件包含定义良好的独立组件, 从而提高了可维护性。
- 容错性-软件能够抵抗部件故障并能够从部件故障中恢复。
- 可维护性-衡量 bug 修复或功能修改的容易程度。高可维护性可以是模块化和可扩展性的产物。
- 可靠性-软件能够在规定的条件下在规定的时间内执行所需的功能。

- 可重用性——在其他项目中使用预先存在的软件的一些或所有方面，而几乎不做任何修改的能力。
- 鲁棒性-软件能够在压力下运行或容忍不可预测或无效的输入。例如，它可以设计为具有对低内存条件的弹性。
- 安全性-软件能够抵御和抵制敌对行为和影响。
- 可用性-软件用户界面必须可用于其目标用户/受众。
- 性能——软件在服务可接受的时间范围内执行任务，不需要太多内存。
- 可移植性-软件应可在多种不同的条件和环境下使用。
- 可扩展性——软件能够很好地适应不断增长的数据或用户数量。
- 设施和资源-开发应在安全的设施中进行，并制定团队和员工管理计划。
- 合规性——软件应根据法规要求的变化进行更新。

供应商应：

- 描述开发/运营人员在船/离开程序和职责分工。
- 描述开发过程，包括编码标准、源代码控制、软件发布、变更管理、问题报告、测试执行等。
- 描述开发代码的备份计划。
- 描述质量控制过程和工具，例如源代码版本控制、静态代码分析、自动构建、成本跟踪等。
- 描述应用程序测试过程和工具。
- 描述发布和部署过程。
- 描述更新产品的过程，包括可用性影响、验证要求等。

- 描述定期监督和检查活动的审计流程。

3.2.4 性能

供应商应根据零部件与 PKI 之间的所有事务的实际数量预测，以及容量管理的内部组件，提供性能规划。

当系统以某种方式降级时，供应商应提供可接受的操作模式。

应监控资源使用情况，以保持合理的利用率，例如 CPU ($\leq 70\%$)、内存 ($\leq 75\%$)、磁盘 (I/O=30%~40%)、网络等。

PKI 应每周 24 小时工作。可用性应高于 99.95%。平均无故障时间 (MTBF) 应为 1000 小时，平均修复时间 (MTTR) 应小于 30 分钟。

3.2.5 安全管理

采埃孚要求：

- PKI 安全应符合采埃孚信息安全政策和相关的采埃孚安全标准/指南/程序。
- 供应商应负责理解并遵守适用于开发地点的政策。
- 控制措施应到位，以监控网络入侵迹象并作出反应。应记录管理检测、调查和应对可能入侵的过程。
- 建议对所有特权用户使用多因素身份验证 (MFA)。
- 应审查和测试使用的第三方库，以避免任何安全漏洞和性能瓶颈。
- 数据必须按照采埃孚应用程序分类标准进行分类，并有适当的安全机制来保护数据，特别是敏感数据。
- 在传输和存储敏感数据时，必须使用经过严格批准的加密算法进行加密。执行加密功能的系统必须以确保加密失败不会以明文形式泄漏数据的方式进行编码。
- 所有加密密钥必须受到保护，以防修改、丢失、未经授权的泄露和破坏。用于生成、存储和归档密钥的设备必须受到物理保护。

- 在生产部署之前，必须删除任何开发、调试或测试代码。
- 必须在所有生产环境中禁用开发人员调试访问。
- 必须禁止在所有生产环境中测试使用调试工具。
- 开发人员对代码库的访问必须受到控制和监控，以确保数据不会发布在批准的位置之外。
- PKI 应遵循采埃孚应用程序安全测试标准，例如道德黑客、漏洞扫描、模糊测试、代码审查等。
- 显示的错误或异常消息不得损害用户数据或应用程序的完整性。
- 事件记录和监控应遵循采埃孚安全记录和审计标准。
- 应建立备份和归档流程以备份关键数据。
- 应制定灾难恢复计划，以避免中断对业务的影响。

供应商应：

- 描述安全计划、方法和流程。
- 描述服务器、网络、防火墙和 IDPS 的安全策略。
- 描述操作系统安全和防病毒/补丁管理的过程。
- 描述密码策略和实施过程。
- 描述远程支持策略。
- 描述常见漏洞预防流程，例如缓冲区溢出、输入验证、SQL 注入等。
- 描述确保接口安全的过程，例如，私人连接和公共互联网连接之间的身份验证和授权。
- 描述静止、传输中的数据安全，以及敏感数据和隐私保护的安全机制。

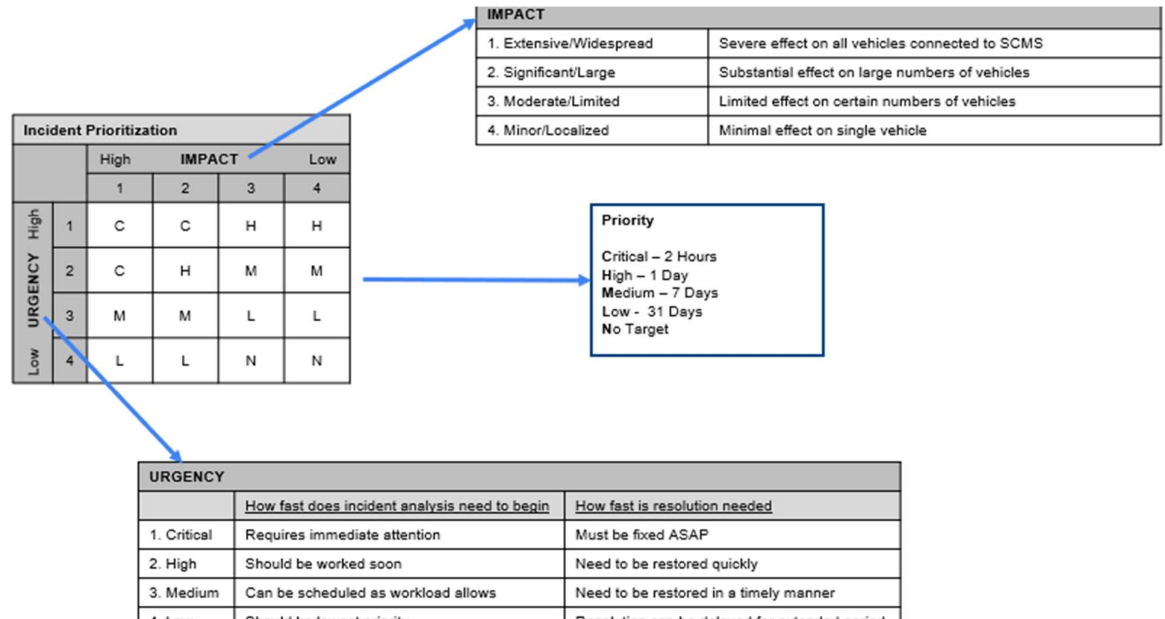
- 描述日志记录和监控管理流程，以及与事件管理流程的集成。
- 描述安全评估流程，如果第三方参与，请注明公司名称。
- 描述安全事件管理流程。
- 描述业务连续性计划和灾难恢复计划。

3.2.6 维护与运营支持

采埃孚要求：

- 事故管理流程必须到位，以支持设施、硬件、软件和服务的不同事故。
- 事件影响、紧急性和优先级定义如下。

注：以下 SLA 用于 L1 支持，采埃孚与供应商之间的 SLA 应遵循供应商在项目阶段提供的解决方案和操作手册。



- 应与 SLA 内的上游支持团队合作解决所有事件。如果存在任何潜在或实际的服务违约行为，应及时上报采埃孚产品所有者。
- 所有事件和解决记录应保存在系统中，并更新知识库。
- 应建立请求管理流程，以支持请求履行，而无需进行重大更改，例如创建新用户帐户。

户、生成报告等。

- 应制定问题管理流程，以支持反复发生的重大事件和根本原因分析。
- 应制定事件管理流程，以支持日志、度量和统计数据的可视化和监控，并防止事件发生。
- 应制定变更管理流程，以支持 bug 修复、新版本发布、基础设施升级和新接口等所需的变更。
- 应制定容量管理流程，以确保设施和硬件/软件容量能够满足业务要求。
- 应制定持续改进流程，以持续改进服务并降低成本。

供应商应：

- 描述支持设施的位置和每个设施的支持人员数量。
- 描述支持组织总体管理的组织架构图。
- 描述列表位置的现场和电话支持时间，以及服务/支持呼叫程序。
- 描述标准服务级别协议，例如典型的呼叫响应时间。
- 描述详细的维护和支持活动，包括采埃孚将要执行的活动。供应商应负责未概述的任何维护。
- 提供维护或支持手册样本和一份典型操作指南，作为评估建议书的附录。
- 描述软件问题隔离和识别程序。
- 描述请求和变更管理流程，包括规则、记录、费用等。
- 描述基于 ITIL 实践的所有操作流程，包括事件管理、事件管理、请求管理、问题管理、能力管理、变更管理和持续改进。

3.3 售后服务要求

3.3.1 质保期

乙方提供从项目验收之日起的一年免费的系统技术支持和服务保证，并对系统硬件产品和软件系统提供免费升级服务。针对设备本身质量原因造成的任何损伤或损坏，乙方免费负责更换。

3.3.2 产品承诺

乙方提供的硬件产品均为原厂商授权的全新正版产品(正品、新品)并在各个方面符合本次采购规定的质量、规格和性能要求。如由于设计、工艺或材料的缺陷而造成的任何缺陷或故障负责,乙方保证其经过正确安装、合理操作和维护保养后,在产品寿命期内的良好运转;

3.3.3 技术支持和服务

乙方提供全方位的、有效的、及时的技术支持和服务，并且提供的技术设备安装、调试、使用、维护、升级和新技术推荐等方面的免费咨询服务。

3.3.4 故障修复时间

如果系统发生故障，乙方承诺 1 小时内响应，针对严重影响甲方业务的故障 2 小时内解决，中等严重等级的故障 4 小时内解决，低等级不影响甲方业务的故障 8 小时内解决。

3.3.5 服务响应时限

承诺提供全年（含节假日）7×24 小时服务响应；在 1 小时内对甲方所提出的要求做出反应，24 小时内排除故障或到达现场给予技术支持。

3.3.6 热线电话

乙方向甲方提供其现场服务联系方式, 并且提供全天候 (7×24) 的热线电话响应服务。

3.4 质量保证

- 乙方提供的硬件产品必须为原厂商授权的全新正版产品(正品、新品)并在各个方面符合本协议规定的质量、规格和性能要求。乙方对由于设计、工艺或材料的缺陷而造成的任何缺陷或故障负责, 乙方保证其货物经过正确安装、合理操作和维护保养, 在货物寿命期内运转良好;
- 乙方必须使用满足需求的、已有用户使用的最新设备报价, 该设备在当前应为设备生产厂商的主流产品, 并在未来较长的时期内能够提供备品备件及扩展模块, 并且同类产品已经在国内用户使用, 在性能及质量方面能提供相关证明。
- 乙方必须是硬件原厂商或其授权的代理商, 并具备相应系统集成能力。
- 乙方应提供所有设备的出厂日期及检验合格证书, 以及证明该设备来源的资质证明。乙方提供的设备配件必须与原设备相配套, 且为原装正品, 在来源及质量方面能提供相关证明。
- 乙方应提供主要设备的工作环境说明, 包括机房要求、供电功率、机柜空间及布线要求等, 乙方所提供的各类设备必须能满足机房正常。
- 详细说明售后服务体系和运作方式。
- 乙方应承诺质保范围内产品故障, 由乙方免费负责更换故障部件。

4.验收要求

4.1 验收标准

- 系统运行正常。
- 软件系统（含定制开发部分）的验收标准以技术要求部分及验收交互物要求为准。针对系统上线后运维期的问题处理及关闭情况，Bug 类问题必须全部关闭。
- 项目文档的验收标准以项目交付物要求中交付物为准。
- 文档验收以准确描述项目各个阶段所得到的结果为合格标准。文档必须详实、准确，配有必要的图片和文字说明，对于不属于项目范围之内但与项目相关的问题，应在文档中提出解决该问题的建议。
- 若文档描述某一独立完整的功能/章节错误，或不完全符合实际功能，则视为验收失败。

4.2 验收步骤

- 第1步： 乙方按照交付物要求交付系统软件的最终版本，双方项目负责人作终验准备工作。
- 第2步： 甲乙双方项目人员共同整理项目各阶段的文档，确认交付齐全。
- 第3步： 双方按照验收标准进行产品功能和项目的验收。
- 第4步： 若未通过验收，针对不合格的部分，乙方须尽快修改完全后，甲乙双方再重新进行验收。
- 第5步： 验收工作通过后，双方签署本阶段《项目终验报告》，正式结束最终验收。

4.3 交付物要求

设备运输由乙方负责安全运抵用户现场，乙方承担由于运输中引起的设备损伤和丢失的责任；要求乙方将设备交付至甲方指定地点；甲方不负责到物流运输公司提货，甲方不对物流公司签收任何设备。甲方只对乙方指定代表共同签收。（交货包括：产品合格证、设备装箱清单、使用说明书等）。

设备签收时，乙方应提供完整的设备到货清单，并提供原厂证明后，双方共同对硬件机箱、产品的型号等进行逐项检验，确保与标的所要求一致后，方可共同对设备进行签收。

设备签收时，发现设备不符合标的要求，甲方有权要求乙方更换设备，由此发生的费用由乙方承担，且不得影响项目进度。

乙方在完成技术标书所描述的工作内容后，作为可评测的工作成果之一，必须在乙方技术方案中列明项目最终交付件清单。交付清单如下（包含但不限于）：

	类别	资 料 名 称	数量
1.	需求设计文档	需求分析报告	1 份
2.		系统设计文档	1 份
3.	实施文档	项目计划	1 份
4.		实际部署运行环境文档	1 份
5.		系统逻辑拓扑图及接口调用	1 份
6.		问题解决跟踪报告（实施问题记录表）	1 份
7.		接口集成文档	1 份
8.		接口测试用例	1 份
9.		接口功能测试报告	1 份

10.		接口性能测试报告	1 份
11.		接口静态扫描报告	1 份
12.		接口漏洞扫描报告	1 份
13.	操作手册	程序员手册、密码服务器手册等各类手册	1 份
14.		软件安装手册	1 份
15.		PKI 系统部署手册	1 份
16.		用户操作手册	1 份
17.		运维手册	1 份
18.	运维文档与培训文档	用户培训材料	1 份
19.		组件失效分析报告	1 份

5.项目培训

5.1 培训目的

通过对甲方技术人员和其他相关人员的培训，使甲方技术人员和其他相关人员的安全意识、安全管理能力、安全基础知识得到提高，使甲方技术人员对本次项目的产品从原理、配置、操作使用与维护等方面有一个透彻地了解，能够更好地进行系统上线后的日常运维。

5.2 技术培训

以系统交付使用后，甲方工程师能够完全对系统进行功能配置、开发、运行维护为目的和标准，乙方需要对该系统项目组的甲方技术人员提供以下培训：

- 1) PKI 系统安装部署及初始化
- 2) PKI 系统架构配置优化调整

- 3) PKI 系统应用配置及调整
- 4) PKI 系统权限设置
- 5) PKI 系统备份及恢复
- 6) PKI 系统扩容安装
- 7) 常见问题处理办法

6. 违约和处罚

(1)在履行本合同过程中, 如果乙方遇到妨碍按时交付和提供服务的情况时, 应及时以书面形式将拖延的事实、可能拖延的时间和原因通知甲方, 并且应当承担非甲方需求变更而引起的延期交付和提供服务的违约责任

(2)除不可抗力条款、甲方变更需求而导致的交付延期、甲方未能配合乙方提供项目必须资料或甲方未能对乙方工作做必要的配合而导致的交付延期外, 如乙方没能按时交付软硬件的, 乙方每逾期一天按合同总金额的 1%向甲方支付违约金; 如超过合同约定交付限期 2 周, 乙方仍不能交付, 则甲方有权解除合同, 要求乙方返还甲方已经支付的全部合同金额并要求乙方合同总金额 30%的违约金。

(3)如乙方提供的软件不符合本合同规定的, 甲方有权根据自行判断而选择要求乙方限期整改, 乙方应当在甲方规定期限内完成整改, 同时按第(2)约定承担违约责任。整改完成后, 乙方应当再次提交甲方验收。若在甲方约定的期限内乙方无法完成整改或整改后仍不能通过甲方的验收, 甲方有权选择单独或同时适用其中的一种或多种违约责任承担方式

(4)乙方自付费用更换替代品。更换后的软件必须符合本合同及附件规定的规格、质量和性能, 同时乙方承担因此发生的费用和甲方遭受的损失。

(5)甲方有权单方解除合同,要求乙方返还甲方已经支付的全部合同金额并要求乙方承担本合同总金额 30%的违约金;乙方收到甲方索赔通知后 30 天内未能以书面形式答复,视为同意甲方提出的索赔要求,乙方应据此履行赔偿义务。

7.附录文件



RQ3_Certificate_S
pecs.pdf